

Authentication

Authentication কী?

Authentication হলো user কে verify করা —
“তুমি আসলেই তুমি কিনা?”

Example:

- Login (email + password)
- Login with Google
- API request এ token check

Authentication vs Authorization (Must-Know)

Topic	Meaning
Authentication	তুমি কে?
Authorization	তুমি কী করতে পারো?

JWT (JSON Web Token)

JWT কী?

JWT হলো **stateless authentication mechanism**
যেখানে server user কে একটা **signed token** দেয়।

Client ---- JWT ----> Server

Server session রাখে না ❌

Token দিয়েই সব verify করে ✅

◆ JWT Structure

JWT = HEADER.PAYLOAD.SIGNATURE

1. Header

```
{  
  "alg": "HS256",  
  "typ": "JWT"  
}
```

2. Payload (Claims)

```
{  
  "user_id": 101,  
  "role": "admin",  
  "exp": 1700000000  
}
```

⚠ Sensitive data রাখা যাবে না (password ❌)

3. Signature

```
HMACSHA256(  
  base64(header) + "." + base64(payload),  
  secret_key  
)
```

👉 Server secret জানে, attacker জানে না

JWT Authentication Flow

1. User login (email + password)
2. Server verifies credentials
3. Server generates JWT
4. Client stores JWT (localStorage / cookie)
5. Client sends request with token

Authorization: Bearer <JWT>

6. Server verifies token
7. Access granted

JWT Security

Best Practices

- Short-lived Access Token (5–15 min)
- Refresh Token (long lived)
- HTTPS mandatory
- HttpOnly cookie preferred

Common Mistakes

- Token localStorage এ রাখা (XSS risk)
- Token revoke না করা
- Very long expiry

Access Token vs Refresh Token

Token	Lifetime	Purpose
Access Token	Short	API access
Refresh Token	Long	New access token

OAuth 2.0

◆ OAuth কী?

OAuth হলো **authorization framework**

যেটা দিয়ে তুমি অন্য platform এর user data access পাও।

 Example:

- Login with Google
- Login with GitHub
- Login with Facebook

◆ OAuth Actors (Interview Gold)

Role	Example
Resource Owner	User
Client	Your App
Authorization Server	Google
Resource Server	Google API

OAuth Authorization Code Flow

1. User clicks "Login with Google"
2. Redirect to Google Auth Server
3. User grants permission
4. Google returns authorization code
5. App exchanges code for access token
6. App uses token to fetch user data

OAuth Token Types

Token	Use
Access Token	API call
Refresh Token	Renew token
ID Token (OIDC)	User identity

OAuth vs JWT

Feature	JWT	OAuth
Type	Token format	Authorization protocol
Use	Auth	Delegated access
Stateless	✓	⚠
Login with Google	✗	✓

👉 OAuth JWT ব্যবহার করতে পারে, but same না ❌

🧠 JWT + OAuth Together

Google OAuth Login

↓

Backend verifies Google token

↓

Backend creates its own JWT

↓

Client uses JWT for APIs

🔥 Architecture

Client

↓

API Gateway

↓

Auth Service (JWT)

↓

Microservices

🔒 Scaling Authentication Challenges

- Token revocation
- Logout from all devices

- Compromised token handling
- Key rotation

FAANG solutions:

- Short-lived token
- Redis blacklist
- Key versioning

Common FAANG Interview Questions

Q1. Why JWT over Session?

- ✓ Stateless
- ✓ Scales horizontally
- ✓ No sticky session

Q2. JWT revoke possible?

- ✓ Yes (Blacklist / Short expiry)

Q3. OAuth secure কেন?

- ✓ No password sharing
- ✓ Scoped access
- ✓ Token expiration

Q4. OAuth vs SAML?

OAuth → Modern APIs

SAML → Enterprise SSO

One-Liner (Interview Killer)

JWT is a stateless authentication mechanism, while OAuth is an authorization framework that allows third-party access without sharing credentials.